Identity, tenant access, settings and administration: review and plan of action

Prepared: 8 September 2026. **Package:** IAM. **Status:** SOURCE_REVIEW_AND_FOCUSED_VERIFICATION; implementation not started by this run.

1. Assessment and scope

This is a source review and focused local verification, not a full runtime certification. Database clients in the selected tests are mocked or injected. No deployed database, authenticated browser, live provider, production telemetry, restore rehearsal or qualified statutory approval was inspected in this run. Unexecuted scenarios below are acceptance requirements, not test results. No application code, migration, business record or deployment is changed by this report.

Accountable roles: Identity engineering and security/privacy reviewer. **Catalog coverage:** settings, administration

Selected verification: 10 passed, 0 failed in the selected suite. Test source. This package owns or consumes PM-CACHE-001.

The highest-risk review questions are direct endpoints must enforce the same authority as the UI; test foreign IDs, expired sessions, invitation replay and last-admin races; separate tenant administration from platform authority and redact sensitive data.

2. Source and architecture map

The source inventory contains 194 matching files, including tests and supporting files. 6 sources were hashed and indexed for targeted review. Prefix inventory counts are discovery aids, not reviewed-file counts. The full list and source hashes are in the source manifest.

Layer	Current source/navigation anchor	Evidence boundary
services	services/security/account-session.service.ts	76 lines; SHA-256 d94096fb8fc8…
hooks	hooks/account-session-recovery.ts	22 lines; SHA-256 51b76e45e3da…
actions	actions/users/verifyOtp.ts	23 lines; SHA-256 b6e6d9696f8e…
actions	actions/users/updateUserPassword.ts	103 lines; SHA-256 34030a5460ab…
components	components/settings/UserDeactivation.tsx	74 lines; SHA-256 1bd3b52af32d…
components	components/settings/user-directory-copy.ts	15 lines; SHA-256 285611a1d96f…

Route/API paths must be expanded from callers; absence from the selected prefix inventory is not a declaration that none exist.

Data declarations

Schema model	Selected declared storage/relationship facts
User	organization Organization @relation(fields: [organizationId], references: [id], onDelete: Cascade); @@index([organizationId]); @@index([organizationId, isActive])
Account	user User @relation(fields: [userId], references: [id], onDelete: Cascade); @@unique([providerId, accountId]); @@index([userId])
Session	user User @relation(fields: [userId], references: [id], onDelete: Cascade); @@index([userId]); @@index([expiresAt])
Role	organization Organization @relation(fields: [organizationId], references: [id], onDelete: Cascade); @@unique([organizationId, code]); @@index([organizationId])
Organization	@@unique([slug]); @@index([slug]); @@index([isActive, deletedAt])
Invite	organization Organization @relation(fields: [organizationId], references: [id], onDelete: Cascade); role Role @relation(fields: [roleId], references: [id], onDelete: Restrict); @@unique([email, organizationId])
Location	organization Organization @relation(fields: [organizationId], references: [id], onDelete: Cascade); @@unique([organizationId, code]); @@unique([organizationId, id])
AuditLog	organization Organization @relation(fields: [organizationId], references: [id], onDelete: Cascade); @@index([entityType, entityId, createdAt]) // entity history view; @@index([organizationId, createdAt])
PublicIdentityAbuseBucket	@@unique([scope, subjectHash]); @@index([blockedUntil]); @@index([updatedAt])

These are schema declarations. Exact migration application, actual constraints/indexes, row populations, query plans and direct-write bypasses remain unverified. See the platform package for migration/restore ownership.

Workflow trace and handoffs

The diagram is the review boundary and required end-to-end trace. Source links and selected tests substantiate only the portions described in this report; it does not claim every edge was exercised.

```
flowchart LR
  A["Business trigger / source"] --> B["Fresh tenant and role authority"]
  B --> C["IAM: owning domain service"]
  C --> D["Transaction and source evidence"]
  D --> E["Event / dependent workflow"]
  D --> F["Read model / query scope"]
  F --> G["UI / export / recovery"]
  E --> H["Reconciliation / assurance"]
```

Workflow	Expected outcome	Evidence disposition
IAM-FLOW-1	Register, verify, invite and recover accounts with bounded tokens and abuse controls	Source navigation and selected mocked/injected assertions only; full end-to-end scenario remains unverified
IAM-FLOW-2	Change roles and tenant authority with fresh checks and retained custodian access	Source navigation and selected mocked/injected assertions only; full end-to-end scenario remains unverified

Workflow	Expected outcome	Evidence disposition
IAM-FLOW-3	Review/revoke sessions and clear protected client state	Source navigation and selected mocked/injected assertions only; full end-to-end scenario remains unverified

Integration contracts: IAM is a shared prerequisite for tenant-facing consumers; examine all callers.. These identify validation/ownership interfaces, not permission to duplicate their implementations. Accounting remains owned by the existing accounting roadmap.

Graph navigation: graph_actions.json node `users_verifyotp_ts`, community 0 (L1); graph_actions.json node `users_verifyotp_verifyotp`, community 0 (L9). Graph extracts predate this review and are not runtime proof.

3. Controls to preserve

The following assertions passed against mocks/injected clients in this run. Preserve their contracts while extending validation; test names are not broader certification claims.

- returns only scoped session display data and no authentication tokens.
- deletes only the reviewed own IDs, preserves current, and saves mandatory evidence.
- rejects changes to the reviewed list before deletion.
- replays the recorded result without deleting newly created sessions.

4. Findings, limitations and risks

PM-CACHE-001 — Several sensitive query families omit tenant or actor identity

CREDIBLE_RISK_REQUIRES_RUNTIME_VALIDATION · P1. Confidence: High for missing key dimensions; cross-session disclosure not demonstrated. Likelihood: Depends on client lifetime and identity-transition behavior; unmeasured.

Evidence: hooks/payments/usePaymentReconciliationDashboard.ts:19; hooks/payroll/usePayrollWorkbench.ts:16; hooks/finance/useFinanceDashboard.ts:7; hooks/posHooks/useOfflineSync.ts:75; lib/providers/query-provider.tsx:14.

Trigger: Organization, actor, permissions or entitlements change while the QueryClient survives.

Expected: Scope-changing transitions cannot render old protected results; result-changing scope belongs in cache identity with cancellation/removal where necessary.

Observed: Payment and payroll keys use fixed prefixes (and limits/IDs); finance/offline keys include filters but no explicit tenant/actor. QueryProvider creates one client with useState. This review did not execute every identity-change path or establish whether navigation remounts/clears it.

Cause / uncertainty: Server-inferred authority is not represented explicitly in these client keys.

Consequences: Stale financial or personnel data may be shown in the wrong context if the client survives. Severity justifies early validation, but this is not a confirmed disclosure incident.

Existing mitigation: Server actions retain authorization and some keys have location/run filters; full reloads could clear caches but are not a complete demonstrated contract.

Correction: Trace every switch/logout/revocation path, then centralize scoped keys and query cancellation/removal; avoid retaining previous protected data across authority changes.

Acceptance: Same-browser two-tenant/actor tests show no old values during loading, errors or revocation; all impacted views refresh after writes.

Owner / estimate: Shared frontend/IAM owner plus affected module owners; 2–3 days to validate; 3–7 engineering days if shared lifecycle correction is required. Estimates are planning judgments, not booked capacity.

Data and rollout: No data mutation required; assess exposure only if runtime reproduction identifies it.

Related earlier work: ACC-010, ACR-22

Additional module scenarios still requiring verification

- **IAM-VERIFY-1:** Direct endpoints must enforce the same authority as the UI. Owner: Identity engineering and security/privacy reviewer. Status: UNVERIFIED. Evidence required: a synthetic failure/success pair and source-to-result tie-out.
- **IAM-VERIFY-2:** Test foreign IDs, expired sessions, invitation replay and last-admin races. Owner: Identity engineering and security/privacy reviewer. Status: UNVERIFIED. Evidence required: a synthetic failure/success pair and source-to-result tie-out.
- **IAM-VERIFY-3:** Separate tenant administration from platform authority and redact sensitive data. Owner: Identity engineering and security/privacy reviewer. Status: UNVERIFIED. Evidence required: a synthetic failure/success pair and source-to-result tie-out.

5. Layer and reviewer dispositions

Lens	Current disposition and remaining proof
Architecture, backend and integrations	Sources/call boundaries inventoried; selected service assertions above. Trace alternate entry points and every handoff before whole-domain approval.
Database, migration and integrity	Named schema models indexed. Deployment, tenant-consistent foreign keys, locking, rollback, scale and backfill/restore not verified.
IAM, privacy, fraud and controls	Apply direct denied-no-read/no-write, role revocation, maker-checker and export redaction tests. A server guard or hidden button alone is insufficient.
Frontend, queries and design system	Client/action entry above inspected statically where present; cache identity, mutation effects and source truth must be traced into actual screens.
UX, accessibility, EN/FR and content	Authenticated role tasks, keyboard/focus, mobile and localized state behavior not executed; no accessibility claim.
Product and business process	Three explicit workflows and supported-scope decisions above; measure task completion and support burden before redesign.
Accounting and financial controls	Direct posting calculation is not applicable to this package; authority, claims and downstream financial effects remain in scope.
Statutory and country review	No new statutory interpretation is made. Escalate any discovered country-specific output to CMP/qualified review.
QA and release	10 passed, 0 failed in the selected suite. linked test source. Unit results do not replace integrated evidence.

Lens	Current disposition and remaining proof
SRE, performance and cost	No latency/load/restore measurements; establish bounded reads, worker age/error metrics, alerts, retries and support ownership before rollout.
AI and agent authority	AI model behavior is not applicable unless a connected agent consumes this module; review that access contract without adding AI features.
Packaging, billing and operations	Confirm actual catalog/entitlement scope and mandatory retained obligations. Provider billing, adoption and customer outcomes are unverified.

6. Ordered execution plan

PM-IAM-01 — Bind current scope, owners and candidate

Status: READY. **Owner:** Identity engineering and security/privacy reviewer. **Effort:** 1–2 reviewer days.

Deliverable: Confirm every listed workflow, supported variant and relevant prior ACC/ACR or STQ-RM item; hash current sources, map entry points and name a domain reviewer.

Acceptance: All material paths have active/legacy/deferred status; no existing change is overwritten.

Prerequisite: Candidate/owner availability; existing historical evidence is a lead..

PM-IAM-02 — Reproduce priority risks and freeze contracts

Status: PLANNED. **Owner:** Identity engineering and security/privacy reviewer. **Effort:** 2–4 reviewer/QA days; isolated environments may extend elapsed time.

Deliverable: Direct endpoints must enforce the same authority as the UI; Test foreign IDs, expired sessions, invitation replay and last-admin races; Separate tenant administration from platform authority and redact sensitive data. Reproduce all linked findings before prescribing data repair.

Acceptance: A scenario ledger records expected/observed behavior, source IDs, denied side effects and remaining blockers.

Prerequisite: PM-IAM-01.

PM-IAM-03 — Implement verified corrections and investigate affected data

Status: CONDITIONAL_ON_CONFIRMED_FINDINGS. **Owner:** Identity engineering and security/privacy reviewer. **Effort:** Use linked finding estimates; otherwise estimate after diagnosis.

Deliverable: Correct the smallest owning boundary; preserve domain history, shared controls and public contracts. Investigate historical impact separately and design reversible repair only if needed.

Acceptance: Focused regression, cross-module tie-out and review prove the correction; no speculative implementation or silent historical rewrite.

Prerequisite: PM-IAM-02. If no defect is confirmed, record a reviewed no-change disposition; this satisfies the decision step without speculative work.

PM-IAM-04 — Verify integrated release and controlled rollout

Status: PLANNED. **Owner:** Identity engineering and security/privacy reviewer. **Effort:** 2–3 reviewer/QA days plus the real operational cycle.

Deliverable: Run isolated DB failure/concurrency scenarios, authenticated role/locale/cache tests, representative performance/export checks and recovery rehearsal. Pilot the agreed supported scope.

Acceptance: No unexplained material mismatch, unauthorized effect or stale evidence claim; domain reviewer and operations owner accept scoped results.

Prerequisite: PM-IAM-03.

Existing accounting and enterprise roadmap estimates must be deduplicated: PM findings linked to ACC/ACR or STQ-RM reuse the owning task. Reviewer-day estimates here are not engineering effort for a complete rewrite and must not be summed with the accounting roadmap as if independent.

7. Data correction, rollout and completion

Investigate exposure using source IDs, time/currency scope, counts and reconciled totals before proposing any repair. Preserve original records, hashes and exports; use reviewed corrective transactions or versioned migration only where necessary. Rehearse backup/restore and rollback in a disposable environment. Code correction and historical reconciliation are separate acceptance items. A query/display issue alone does not justify rewriting financial history.

Start with an agreed eligible pilot and observe a complete relevant cycle (sale/refund/shift; receiving/invoice/payment; payroll period; or close). Stop expansion on unauthorized effects, unexplained material mismatches, duplicate effects or stale proof. Record incident owner, recovery route and the data needed for investigation. No pilot or release is authorized or completed by this document.

Completion requires disposition for every workflow, current-source evidence for each significant claim, tested or explicit blocked failure scenarios, domain-reviewed corrective work and an understood operational handoff. The tailored audit prompt provides the full repeatable execution brief.

8. Evidence and provenance

Commit: `a05a41ef66cd5d98fd69ae3df18225795f912232` ; branch: `codex/migration-control-plane-release-2026-08-29` . Initial capture: 2026-09-08T14:41:48.494Z. Dirty workspace preserved; claims bind to file hashes, not clean HEAD. Unit command: 2026-09-08T14:43:08.844Z to 2026-09-08T14:44:14.458Z; exit 1. See exact command, assertion results, test log and shared evidence index. Historical reports were used for navigation and work deduplication; their earlier pass counts are not included in this run.